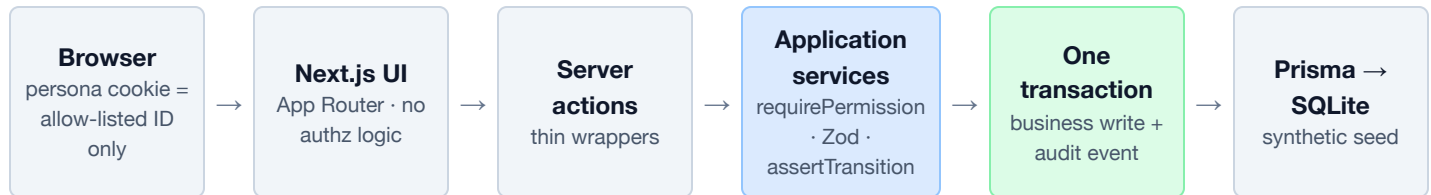


Fintech Operations Console — Key Decisions

Objective: test whether Devin-assisted custom development yields a reusable, engineering-owned internal-tools golden path worth piloting against a ~\$250K/yr Power Apps footprint. **Scope:** one deep workflow (KYC) proves depth; two thin modules (refunds, feature flags) price repetition — the economics of apps 2–10 — on synthetic data with deliberately simulated identity.

ARCHITECTURE — AS IMPLEMENTED (VERIFIED BY SOURCE AUDIT + 13/13 SERVICE-LEVEL TESTS)



Server resolves user & role from the database — the client never asserts a role. Audit trail: who, what, before/after, reason; append-only at the application layer. Full trace: *deliverables/evidence-matrix.md*.

KEY DECISIONS — WHY · PROVES · DOES NOT PROVE · PRODUCTION IMPLICATION

1 · Code-based golden path, not a low-code platform

Why: control, testability, repeatability for engineering-owned tools. **Proves:** a 4th module can look like the 3rd — marginal cost falls with reuse. **Doesn't prove:** any replacement for connectors, Dataverse, DLP, or citizen development. **Implication:** custom fits engineering-owned apps; forms-over-data stays on Power Apps.

2 · One deep KYC slice + two thin modules

Why: depth shows regulated-workflow fit; thinness isolates the reusable spine. **Proves:** shared components and service patterns carry across modules. **Doesn't prove:** per-app production cost — the pilot must measure it. **Implication:** the reuse claim is structural, not yet economic.

3 · Central server-side permissions, transitions, validation

Why: one reviewable place for "who can do what" and "what may change into what." **Proves:** denials are testable first-class cases — a reviewer's flag toggle is refused by the server. **Doesn't prove:** SSO/MFA, record-level authz, segregation of duties. **Implication:** identity and fine-grained authz are pilot-blocking work.

4 · Audit event in the same transaction as every change

Why: "no change without a trail" as a structural guarantee. **Proves:** fault-injection test — if the audit write fails, the business write rolls back. **Doesn't prove:** tamper-evident retention; append-only holds at the app layer only. **Implication:** regulated flows need immutable storage + approved retention first.

5 · Repository-as-contract for Devin (AGENTS.md · module Skill · PR template) — human review as the merge gate

Why: encode the non-negotiable rules so agent output conforms by construction. **Proves:** with explicit conventions and tests, an agent can extend the path consistently. **Doesn't prove:** autonomy without oversight, or any build-time figure — the repository does not independently substantiate an end-to-end build-duration claim. **Implication:** budget for permanent human review and framework ownership (est. 0.5–1 FTE — assumption, to be measured in the pilot).

Bottom line: build-vs-buy is per-app, not tenant-wide. Custom wins only where engineering owns the tool in production, needs code-level control or deep internal integration, and the workflow is testable; Power Apps wins everywhere else — identity, governed data, connectors, DLP, and ALM come with the license. **Largest unresolved risk:** un-built production controls (SSO, record-level authz, source-of-truth integration, tamper-evident audit, monitoring) plus standing platform ownership can consume the ~\$250K/yr ceiling. **Next step:** confirm the real seat mix behind the spend; take one pilot — feature-flag administration — to a true production bar and through security review; decide app #2 from measured hours, support burden, and lead time.